

ThreatLens: Claim-Level Grounding Verification for LLM-Extracted Cyber Threat Intelligence

Tushar

Independent Researcher

tusardey77@gmail.com

Abstract

Large language models are increasingly proposed for automating cyber threat intelligence (CTI) extraction, but existing benchmarks evaluate them with precision-style accuracy metrics against static gold labels. We argue this measurement approach is unsafe for operational deployment, and we present THREATLENS, an open-source pipeline that performs deterministic, claim-level grounding verification of LLM-extracted CTI against three authorities: the National Vulnerability Database, MITRE ATT&CK STIX data, and the source document itself. Every atomic claim (CVE, indicator of compromise, ATT&CK technique, threat actor, malware family) receives one of five verdicts under a taxonomy that separates *fabricated* entities from entities that are real but *ungrounded* in the source, *misabeled* metadata, and claims that are simply *unverifiable* because no authority can confirm them.

We evaluate five open-weight models on 94 CISA advisories published after the models’ training cutoffs, plus two indicator-list CTI events. Four findings emerge. (i) Hallucination is task-dependent rather than model-intrinsic: the same model scores 0.00% on indicator-copying tasks and 6.39% on narrative advisories requiring inference. (ii) Precision metrics conceal *silent failure*: one model returned well-formed but empty extractions on 100% of its successful runs over CVE-bearing advisories, which a precision-only benchmark would report as flawless. Even the best model silently returns nothing on 11.2% of CVE-bearing advisories. (iii) Two reproducible failure modes appear at temperature 0: parametric-memory CVE imports and systematic ATT&CK sub-technique confabulation. (iv) Following NIST’s April 2026 decision to abandon universal NVD enrichment, existence checking against vulnerability registries fails precisely on the freshest advisories: 9 of 11 CVEs cited verbatim in same-week ICS advisories were absent from both NVD and CVE.org. We further report the verifier’s own audit trail: five classes of verifier false positive discovered by manual adjudication and fixed under regression test, which we argue should be a standard reporting requirement for automated CTI evaluation. Code, corpus manifests, and per-claim verdicts are released.

1 Introduction

Security operations centres face more threat reporting than analysts can read. Large language models (LLMs) are an appealing remedy: they can read an advisory and emit structured indicators, techniques, and actor attributions in seconds. A growing body of work benchmarks this capability [2, 1, 5], and a complementary line of work documents its unreliability [12, 4].

Our concern is with how that unreliability is *measured*. Existing CTI benchmarks score model outputs against static gold labels and report accuracy-style aggregates. Three problems follow. First, gold labels age: the threat landscape moves faster than benchmark curation, and static datasets leak into training corpora. Second, an accuracy score over a fixed answer key says nothing about whether a specific claim in a specific report is safe to act on, which is the question an analyst actually asks. Third, and most seriously, precision-style metrics are blind to omission: a model that extracts nothing cannot be wrong.

We take a different position. Rather than scoring models against an answer key, we verify each extracted claim against the authorities that operational security already trusts, at extraction time, deterministically, and without a human in the loop. This reframes evaluation as *grounding* rather than *accuracy*, and it yields a tool that is useful in a pipeline, not only in a leaderboard.

Contributions.

- THREATLENS, an open-source claim-level CTI verifier that cross-checks LLM output against NVD [13], CVE.org [20], MITRE ATT&CK STIX [19], and source-document provenance (Section 3).
- A five-verdict taxonomy that distinguishes fabricated entities from real-but-ungrounded ones—a distinction absent from prior CTI evaluation and essential for diagnosing parametric-memory leakage.
- An evaluation on 94 post-cutoff CISA advisories showing that hallucination rates are task-dependent, that silent failure is prevalent and invisible to precision metrics, and that two specific failure modes reproduce deterministically (Section 5).

- Quantification of vulnerability-registry lag as a verification failure mode, in the wake of NIST’s 2026 curtailment of NVD enrichment [14, 11].
- An explicit verifier audit trail: five false-positive classes found by adjudicating flagged claims, each fixed and regression-tested. We argue this should be reported as standard practice (Section 6).

2 Background and Related Work

CTI benchmarks. CTIBench [2] evaluates LLMs across CTI knowledge questions, CVE-to-CWE mapping, severity prediction, ATT&CK technique extraction and actor attribution. AthenaBench [1] extends it with a dynamic dataset pipeline, deduplication and a risk-mitigation task, finding open models substantially behind proprietary ones on reasoning-heavy tasks. Both are answer-key benchmarks: they measure whether the model matches a label, not whether a claim is grounded in the document that produced it.

Reliability studies. Mezzi et al. [12] evaluate consistency and confidence over 350 threat reports and find LLMs inconsistent and overconfident on real-size inputs. [4] categorises CTI failure modes—spurious metadata correlations, contradictory sources, and constrained generalisation to emerging threats—using a human-in-the-loop framework. These works diagnose; neither ships an automated verifier. Feng and Sakurai [10] survey LLM integration in intrusion detection and its attendant risks.

Closest work. CyberThreat-Eval [5] is an expert-annotated benchmark drawn from a production CTI workflow, with analyst-centric metrics; its agent integrates external ground truth and expert feedback. It observes, as we do, that LLMs “struggle to distinguish correct from incorrect information” and that external ground truth for technical details is often absent. It differs from THREATLENS in three ways: it is built around a proprietary corporate workflow with expert annotators, the verification layer is not released as a standalone reproducible artifact, and it evaluates frontier proprietary models rather than the open models a resource-constrained SOC can actually run.

Grounding and hallucination detection. General-purpose grounding frameworks such as GSAR [7] partition claims into grounded/ungrounded typologies for multi-agent LLM systems, and domain-grounded retrieval pipelines perform atomic claim verification [6]; neither is specialised to CTI authorities. KGV [3] assesses CTI credibility with knowledge graphs, targeting source credibility rather than claim-level grounding of extractions. To our knowledge no open-source tool performs deterministic claim-level

verification of LLM-extracted CTI against vulnerability and adversary-technique registries.

3 ThreatLens Design

3.1 Claim model

An extraction is decomposed into atomic *claims*. Each claim carries a type (CVE, IoC-IP, IoC-domain, IoC-URL, IoC-hash, IoC-email, ATT&CK technique, threat actor, malware), a value, an optional label (product name, technique name), and an evidence span the model is instructed to quote verbatim from the source.

3.2 Verdict taxonomy

Each claim receives exactly one verdict:

VERIFIED the entity exists in an authority, is grounded in the source document, and its metadata is consistent.

FABRICATED the entity does not exist in any authority and is not present in the source (e.g. a malformed indicator, an invalid ATT&CK identifier, an unregistered and unquoted CVE).

UNGROUNDED the entity is real but the source document does not support it. This isolates *parametric-memory import*: the model supplies a fact from training rather than from the document.

MISLABELED the entity is real and grounded but the attached metadata is wrong (e.g. a valid technique identifier paired with the name of a different technique).

UNVERIFIABLE no authority can adjudicate the claim—the API is unreachable, or the entity is source-attested but absent from all registries. Verdicts are never guessed; this is a fail-safe state, not a failure.

The UNGROUNDED / FABRICATED split is the taxonomy’s key contribution. A real CVE that the source never mentions is not an invented fact, but it is equally unsafe in an automated pipeline: it is an unattributable assertion. Prior CTI evaluation collapses both into “incorrect”.

3.3 Authorities

Vulnerabilities. CVEs are checked against NVD API 2.0 [13] with an on-disk cache and rate limiting. Because NVD enrichment is now incomplete by policy [14], a negative NVD result triggers a secondary lookup against CVE.org CNA records [20]. Only a claim absent from both *and* absent from the source text is FABRICATED.

Adversary behaviour. Technique identifiers, intrusion-set aliases and malware/tool names are checked against the MITRE ATT&CK Enterprise STIX 2.1 bundle [19, 15, 18]

(v18.1: 835 techniques, 580 actor aliases, 1,062 malware and tool names).

Provenance. Every claim type is additionally checked for literal presence in the source document after defanging normalisation (`hxxp`→`http`, `[.]`→`.`). Indicators must appear verbatim: there is no legitimate mechanism by which a model can know a C2 address or file hash that the report does not state. Technique identifiers are treated differently, since they are analyst inferences rather than quotations; for these the model’s evidence span must appear in the source.

3.4 Pipeline

Ingestion normalises CISA advisories [9] and MISP OSINT events [21, 8] into a common schema with publication dates. A provider-agnostic client supports local Ollama [16] and any OpenAI-compatible endpoint [17]. Extraction uses a fixed JSON-schema prompt at temperature 0; the pipeline never filters model output, so raw behaviour is measured. Verification is deterministic, and results (including every per-claim check) are appended to JSONL with resume support. A separate re-verification tool recomputes all verdicts under revised rules without re-invoking any model, which makes verifier refinement cheap and auditable.

4 Experimental Setup

Corpora. The primary corpus is 94 unique CISA advisories [9] collected between 2026-06-12 and 2026-07-25 (ICS advisories, joint alerts, and KEV catalogue additions), mean length 13,104 characters, containing 285 distinct CVE mentions. All were published after the evaluated models’ training cutoffs, which removes memorisation as an explanation for correct extraction. A secondary corpus of two TLP:WHITE CIRCL MISP OSINT events [8] (Turla infrastructure; Operation Dust Storm; ≈235 indicators, mean 3,754 characters) provides an indicator-copying contrast condition.

Models. We attempted twelve open-weight endpoints; five produced usable output (Table 1). Seven produced none because of persistent upstream rate limiting or endpoint withdrawal—a result we report rather than hide (Section 8).

Protocol. Temperature 0, fixed prompt, up to three runs per report per model. Claims are never filtered before verification. A deliberately corrupted extraction with injected errors of every taxonomy class is carried through the pipeline as a negative control on every re-verification.

Table 1: Grounding verdicts by model and corpus. CISA = narrative advisories (inference required); MISP = indicator lists (copying). Hallucination rate = (fabricated + ungrounded + mislabeled) / verifiable claims.

Model	Corpus	Runs	Claims	Halluc.
Nemotron-3-Super 120B	MISP	6	739	0.00%
Nemotron-3-Super 120B	CISA	143	590	6.39%
gpt-oss-20B	MISP	1	42	0.00%
gpt-oss-20B	CISA	39	113	23.71%
Gemma-4 31B	MISP	1	39	0.00%
Nemotron-nano 9B	CISA	5	7	0.00%
Nemotron-3-nano 30B	CISA	10	0	—
Negative control	MISP	1	8	87.50%

Table 2: Yield analysis over CVE-bearing advisories. *Silent failure* = well-formed but empty extraction from a report that does contain CVEs; *abstention* = empty extraction from a report with none.

Model	Runs	Yield	Silent	Abstain
Nemotron-3-Super 120B	143	86.7%	11.2%	2.1%
gpt-oss-20B	39	97.4%	2.6%	0.0%
Nemotron-nano 9B	5	80.0%	0.0%	20.0%
Nemotron-3-nano 30B	10	0.0%	100%	0.0%

5 Results

5.1 Hallucination is task-dependent

Table 1 shows the same model, prompt and verifier producing 0.00% hallucination on indicator-list events and 6.39% on narrative advisories (Nemotron-120B), and 0.00% versus 23.71% for gpt-oss-20B. The distinction is not report length but task type: indicator lists require copying, whereas advisories require inferring techniques and mapping products, and inference is where grounding fails. A benchmark composed mainly of extraction-from-list tasks will therefore report reassuring numbers that do not transfer to the narrative reports analysts actually triage.

5.2 Silent failure is invisible to precision metrics

Nemotron-3-nano 30B returned syntactically valid JSON containing empty arrays on *every* successful run. Its hallucination rate is undefined because it made no claims; a precision-only benchmark would report it as making no errors. Table 2 separates this from legitimate abstention by asking whether the source document contained CVE identifiers at all. All ten of the 30B model’s empty runs were on advisories that did contain CVEs—up to seven in one case—so they are unambiguous failures, not appropriate silence.

The result generalises beyond the smallest models: the best-performing model in our study silently returns nothing

on 11.2% of CVE-bearing advisories while reporting an excellent 6.39% hallucination rate. In an automated defence pipeline a silently dropped advisory is arguably more dangerous than a visible error, because nothing signals that review is needed. We therefore argue that *yield* and *silent-failure rate* must be reported alongside any precision-style CTI metric.

5.3 Two reproducible failure modes

Parametric-memory CVE import. On KEV-catalogue alerts whose page text announces additions without listing identifiers, models supplied CVE identifiers that are real, correctly formatted, and absent from the source (e.g. CVE-2026-10520, CVE-2026-42271, CVE-2026-50751; 5 of 5 runs). These are **UNGROUNDED**: the model answered from training memory rather than from the document. Under a conventional answer-key benchmark such a claim may well be scored *correct*, since the CVE is genuinely associated with the alert. Under operational conditions it is an unattributable assertion whose provenance cannot be traced to the input.

ATT&CK sub-technique confabulation. Models pair valid technique identifiers with the names of neighbouring sub-techniques: T1071.001 (*Web Protocols*) labelled “Application Layer Protocol: MQTT” (correctly T1071.005), and T1087.002 (*Domain Account*) labelled “Cloud Account Discovery” (correctly T1087.004). These recurred identically across all runs at temperature 0, so they are systematic properties of the model rather than sampling noise. Because both components are individually plausible, downstream consumers keyed on the identifier would silently ingest a wrong technique.

5.4 Registry lag defeats existence checking

NIST curtailed universal NVD enrichment in April 2026, prioritising only KEV-listed, federally used, and critical software [14, 11]. We observe the operational consequence directly: across three same-week ICS advisories, 9 of 11 CVEs quoted *verbatim* in the advisory text were present in neither NVD nor CVE.org, while the remaining two resolved normally. A naive verifier flags all nine as fabrications. The correct verdict is **UNVERIFIABLE**: the model was faithful, and the registries were merely behind. Over the full study, 27 claims from the 120B model were quarantined this way. Existence checking against vulnerability registries thus degrades exactly on the freshest—and most operationally urgent—advisories, which we believe is an underappreciated constraint on automated CTI validation generally.

6 The Verifier Audit Trail

A verifier that is itself wrong produces confident nonsense. We therefore adjudicated every flagged claim by hand and treated verifier false positives as first-class findings. Five classes emerged, each fixed and pinned by regression tests (23 tests at time of writing):

1. **Indicator type confusion.** A model extracted an X.509 SHA-1 fingerprint line into an `ip` field. The artifact is real and grounded; only the type is wrong. Rule: grounded-but-malformed indicators are **MISLABELED**, not **FABRICATED**.
2. **Registry lag** (Section 5): grounded but unregistered CVEs are **UNVERIFIABLE**.
3. **Parent-prefixed technique labels.** “Unsecured Credentials: Private Keys” is correct usage for T1552.004 but failed naive string similarity against the official sub-technique name.
4. **Product-name comparison.** Comparing a short product label against a long CVE description with sequence similarity systematically under-scores correct labels; token-overlap comparison fixed this.
5. **Supply-chain product mismatch.** ICS advisories name the *affected product* (e.g. Hitachi Energy RTU500) while NVD describes the *vulnerable component*. A label grounded in the advisory is faithful extraction; we mark these **VERIFIED** and flag them, which incidentally yields a dataset of supply-chain vulnerability cases.

Before these fixes the measured hallucination rate for the 120B model was 17.5%; after adjudication it is 6.39% on the same data. The difference is entirely verifier error. We report this trajectory deliberately: any automated CTI evaluation that has not published such an audit should be assumed to contain false positives of similar magnitude.

7 Discussion

Three implications follow for practitioners. First, precision is not safety: deployment decisions require yield and silent-failure rates, and a model that abstains on hard inputs is not thereby safe. Second, verification must be multi-authority and fail-safe, because single-source existence checks now break on recent advisories by policy rather than by accident. Third, the grounded/ungrounded distinction should be enforced in pipelines: a real CVE that the source never mentions must be surfaced for review, not silently promoted to an action.

For researchers, our results suggest that CTI benchmark scores are not comparable across task types, and that reporting a single hallucination rate per model obscures the operative variable, which is what the task demands of the model rather than what the model is.

8 Limitations

Our study is preliminary in scale and we state its bounds plainly. The corpus is 94 advisories dominated by ICS bulletins from a single publisher; adversary-narrative reports from vendor research would exercise actor and technique extraction more heavily. Sample sizes are unequal and small for three of five models (5–39 successful runs), so their point estimates should be treated as indicative only; only the 120B model has enough data for confident claims. Model availability, not compute, was the binding constraint: across the study we recorded 305 dropped connections and roughly 120 rate-limit rejections on free endpoints, and 7 of 12 attempted models produced no usable output at all. Reproducibility of free-tier evaluation is therefore poor, and we recommend local inference [16] or paid endpoints for future work.

Verification covers only claim types with machine-readable authorities. Narrative assertions—attribution reasoning, impact assessment, campaign linkage—remain outside scope, and our hallucination rates should not be read as covering them. Adjudication of flagged claims was performed by one annotator (the author); an independent-annotator study with inter-rater agreement is required before the verifier’s own precision can be stated numerically, and we regard this as the most important piece of remaining work. Finally, runs were conducted at temperature 0 with a single prompt; prompt sensitivity and retrieval-augmented variants are unexplored.

9 Availability

THREATLENS is released with the verifier, ingestion modules for CISA and MISP sources, the corpus manifest with publication dates, per-claim verdict records, the regression test suite, and the re-verification tool that reproduces every number in this paper from stored extractions without re-invoking any model.

<https://github.com/TODO/threatlens>

References

- [1] Md Tanvirul Alam, Dipkamal Bhusal, Salman Ahmad, Nidhi Rastogi, and Peter Worth. AthenaBench: A dynamic benchmark for evaluating LLMs in cyber threat intelligence, 2025.
- [2] Md Tanvirul Alam, Dipkamal Bhusal, Le Nguyen, and Nidhi Rastogi. CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2024. arXiv:2406.07599.
- [3] Authors to be completed from arXiv:2408.08088. KGV: Integrating large language models with knowledge graphs for cyber threat intelligence credibility assessment, 2024.
- [4] Authors to be completed from arXiv:2509.23573. Uncovering vulnerabilities of LLM-assisted cyber threat intelligence, 2025.
- [5] Authors to be completed from arXiv:2603.09452. CyberThreat-Eval: Can large language models automate real-world threat research?, 2026.
- [6] Authors to be completed from arXiv:2603.17872. Mitigating LLM hallucinations through domain-grounded tiered retrieval, 2026.
- [7] Authors to be completed from arXiv:2604.23366. GSAR: Typed grounding for hallucination detection and recovery in multi-agent LLMs, 2026.
- [8] Computer Incident Response Center Luxembourg (CIRCL). MISP OSINT feed (tlp:white), 2026. Accessed 2026-06-12.
- [9] Cybersecurity and Infrastructure Security Agency. Cybersecurity alerts & advisories, 2026. Accessed 2026-07-25.
- [10] Yaokai Feng and Kouichi Sakurai. Network intrusion detection: Evolution from conventional approaches to LLM collaboration and emerging risks, 2025.
- [11] Help Net Security. NIST admits defeat on NVD backlog, will enrich only highest-risk CVEs going forward, April 2026. Accessed 2026-07-25.
- [12] Emanuele Mezzi, Fabio Massacci, and Katja Tuma. Large language models are unreliable for cyber threat intelligence. In *European Symposium on Research in Computer Security (ESORICS)*, 2025. arXiv:2503.23175.
- [13] National Institute of Standards and Technology. National Vulnerability Database API 2.0, 2026. Accessed 2026-07-25.
- [14] National Institute of Standards and Technology. NIST updates NVD operations to address record CVE growth, April 2026. Accessed 2026-07-25.
- [15] OASIS Cyber Threat Intelligence Technical Committee. STIX version 2.1, OASIS standard, 2021.
- [16] Ollama. Ollama: Run large language models locally, 2026. Accessed 2026-07-25.
- [17] OpenRouter. OpenRouter unified LLM API, 2026. Accessed 2026-07-25.
- [18] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MTR170202, The MITRE Corporation, 2018. Revised 2020.

- [19] The MITRE Corporation. ATT&CK STIX data (enterprise), version 18.1, 2026. Accessed 2026-07-25.
- [20] The MITRE Corporation. CVE services API (CVE record retrieval), 2026. Accessed 2026-07-25.
- [21] Cynthia Wagner, Alexandre Dulaunoy, Gérard Wagner, and Andras Iklody. MISP: The design and implementation of a collaborative threat intelligence sharing platform. In *Proceedings of the 2016 ACM Workshop on Information Sharing and Collaborative Security (WISCS)*, 2016.